

Detection Engineering Project Notes

Writing Detection Rules with Sigma

Explanation for Project Managers & HR

From Basic Concepts to Advanced Professional Practice

Project	Detection Engineering – Sigma Detection Rules
Role Alignment	Detection Engineer / Cybersecurity Professional
Key Tools	Sigma, Sigma-CLI, MITRE ATT&CK, Splunk / Wazuh / Elastic
Purpose of this document	Help non-technical and semi-technical stakeholders understand the project value, scope, and skills demonstrated.

1. What is this project? (Basic Level)

This project is about **building security detection rules**.

In simple terms: companies collect large volumes of logs from computers and servers. Attackers leave traces in those logs (for example, when they run suspicious PowerShell commands). A **detection rule** is a smart filter that examines the logs and raises an alert when something dangerous happens.

I used a standard language called **Sigma** to write these rules. Sigma is a universal format — once a rule is written in Sigma, it can be converted to work in different security tools (Splunk, Wazuh, Elastic, and others).

Goal of the project: Demonstrate the ability to design, write, test, and improve real detection rules that help security teams catch attackers earlier and with higher confidence.

2. Why does this project matter? (Business Value)

Point	Explanation for PM / HR
Detection Engineering is high-value	It sits above normal SOC (Security Operations Center) work. Companies pay more for people who can build detections, not only respond to alerts.
Shortage of skilled people	Many teams struggle to hire Detection Engineers. Proven work on GitHub is strong evidence of practical ability.
Portfolio proof	Instead of only claiming knowledge of Sigma, this project shows actual rules, documentation, and a testing process.
Interview advantage	The candidate can walk through one complete rule from start to finish — this builds confidence with technical interviewers.

Salary context (for HR awareness): Detection Engineer roles commonly range from roughly £45k–70k in the UK and \$95k–130k in the US, depending on experience and location.

3. What was actually built (Project Scope)

The work followed a clear professional 4-step process:

Step 1 – Pick one attacker behaviour

Realistic attack techniques were selected using the MITRE ATT&CK framework (the industry standard), including:

- Encoded PowerShell commands
- Creation of a new local administrator account
- Registry Run-key persistence
- Suspicious access to LSASS memory (used for stealing credentials)

Key principle: One behaviour = one rule. Overly broad “catch-everything” rules were deliberately avoided.

Step 2 – Write the detection rule

Clean, professional rules were written in **Sigma YAML** format. Each rule includes a clear title and description, technical detection logic, MITRE ATT&CK mapping, known false positives, and a severity level.

Step 3 – Convert and prove it works

The Sigma rules were converted into queries for real security tools (for example, Splunk). They were then tested in a lab by deliberately running the attack behaviour and confirming that the alert actually fired.

“A rule that has never fired in front of you is only a guess, not a real detection.”

Step 4 – Hunt false positives

Legitimate activity that could also trigger the rule (IT scripts, backup software, monitoring agents, etc.) was analysed, and a disciplined approach to reducing noise was documented.

4. Intermediate Level – What makes the project solid

- **Detection-as-Code approach:** Rules are written as code (YAML), version-controlled, and reusable.
- **Portability:** One Sigma rule can be converted to multiple SIEM platforms.
- **Quality standards:** Proper structure, unique IDs, false-positive notes, and ATT&CK tags.
- **Lab validation:** Work did not stop at writing the rule — it was proven to work.
- **Documentation:** Clear step-by-step notes so others can understand the reasoning.

5. Advanced Level – Professional Detection Engineering Thinking

This project demonstrates practices closer to senior-level detection engineering:

Advanced Practice	Why it matters
Behaviour-focused detection	Looks at how attackers act, not only known bad files or IP addresses.
ATT&CK mapping	Aligns detections with the global standard used by most security teams.
False-positive ownership	Every exception is documented with a reason and owner — this reduces long-term noise.
Validation culture	Insisting on proof that the rule fires builds trust in the detection.
One-behaviour discipline	Prevents noisy, unmaintainable rules that create alert fatigue.
Conversion pipeline awareness	Understanding how Sigma translates into Splunk / Elastic / Wazuh queries.

These habits help separate a junior analyst from a Detection Engineer.

6. How this project helps an organisation

In a real security team, this type of work would help by:

- Increasing the chance of catching real attacks earlier
- Reducing reliance on only basic antivirus or simple alerts
- Creating reusable, well-documented detections
- Improving the quality of alerts that reach the SOC team
- Supporting audit and compliance needs through mapped, explainable rules

7. Skills demonstrated (for HR / hiring managers)

Technical skills

- Sigma rule development
- MITRE ATT&CK framework
- Detection engineering lifecycle
- SIEM query concepts (Splunk / Wazuh / Elastic)
- Lab testing and validation
- False-positive analysis

Professional skills

- Structured problem-solving
- Clear documentation
- Quality mindset
- Ability to explain technical work to both technical and non-technical stakeholders

8. Short explanation for a meeting (30–60 seconds)

"This project shows how I design security detection rules. I take a specific attacker behaviour, write a clean Sigma rule for it, convert that rule so it works in a SIEM tool, test it in a lab to prove the alert fires, and then carefully reduce false positives. The goal is to create high-quality, maintainable detections that help security teams catch real threats with less noise. It is the core skill set used by Detection Engineers."

9. Suggested answers to deeper questions

Question	Suggested direction
Why Sigma?	It is vendor-neutral. Write once, use across different security tools.
How do you know the rule is good?	It is mapped to ATT&CK, tested in a lab, and false positives are documented.
What is the hardest part?	Reducing false positives without creating dangerous gaps in coverage.
How does this help the business?	Better detections lead to faster response and lower risk of major incidents.
What would you do next?	Expand the rule set, add automated testing, and integrate into a detection-as-code pipeline.

10. Summary for Project Managers & HR

This is **not** a simple coding exercise. It is a complete demonstration of the **Detection Engineering workflow** used in modern cybersecurity teams:

Research → Write → Convert → Prove → Tune

It shows practical skill, professional discipline, and the ability to produce work that is ready for a real security operations environment.

Document prepared for Project Manager and HR discussions · Detection Engineering Portfolio Project